VULTR AGENT RUSH, CHALLENGE 1, BLAST RADIUS ZERO

# Canary Cage for MCP

An agent that writes and runs behavioural probes against MCP tools inside isolated Vultr sandboxes, discovers what each tool actually touches, and replays the identical probe under a human-approved least-privilege contract to prove the tool still works with less authority.

Vanta Point Labs. Timotej Cvikl, Bernard Liu, Jeremy Wong (advisor)

PROBLEM

# A tool schema says how to call a tool, not what it touches

An MCP server can return a perfectly correct answer and, on the way, read a .env file, copy an SSH key and send both somewhere. Nothing in the description or the JSON schema will show that.

The teams who approve MCP servers for coding assistants and internal agent platforms have a binary choice today. Trust the server or reject it, with no evidence either way.

BUYER

# Platform, developer experience and application security teams

They own the decision to admit a tool. They want evidence, a narrow approved contract, and proof the tool still works under it.

The artefact they get is an evidence bundle and a hashed replay, which fits registries and CI gates as the next step. Valuable even for honest tools, because most tools are built without any thought for least privilege.

# Nine steps. The model writes and proposes. Code validates, enforces and decides.

- Inspect the server, then Vultr Serverless Inference writes a probe against a four-function harness. An AST validator accepts or rejects it, one repair round.
- Run A is the probe minus its tool call. Run B is the probe on a private network whose only exit is our recording gateway. Host-side strace on both.
- Every event is labelled against the baseline and the tool-call window. The model proposes the narrowest contract. A person approves. A deterministic compiler enforces it. Run C replays the identical probe by hash.

# Real executed work with real failure modes

```
import { startServer, request, notify, assertSchema } from "@canary-cage/harness";
```

The probe may import exactly this. The validator parses the syntax tree and requires the lifecycle in order, literal tool arguments that match the live tools/list schema, no dynamic code, no other globals. It restricts what a probe can say. It is not a security boundary. Docker is.

The accepted probe is frozen by hash. Discovery and replay run the same bytes.

# Same probe, same fixture, less authority

| DISCOVERY (RUN B) | ENFORCED REPLAY (RUN C) |
| --- | --- |
| Repository summary returned | Same summary returned |
| .env read observed | .env access denied, EACCES |
| SSH key read observed | SSH key access denied, EACCES |
| Canary egress attempted, caught at gateway with bait in body | No network available, attempt refused (ENETUNREACH) |
| Contract exceeded | Useful output preserved within approved contract |

Replay identity is four hashes, probe, call, image id, fixture digest. Contract hash shown apart.

# One VM runs everything. Every model call is Vultr Serverless Inference.

**Vultr Cloud Compute.** The orchestrator runs on the VM host under systemd. Docker on the same VM runs each fresh sandbox and the recording gateway. strace attaches from the host. The public URL resolves to this VM.

**Vultr Serverless Inference.** Probe synthesis, probe repair, contract proposal, verdict explanation. OpenAI-compatible endpoint, temperature 0. Each call is shown in the product with model, latency and tokens. No other provider anywhere.

BUSINESS VALUE

# A repeatable approval workflow, not a one-off stunt

Enterprise MCP adoption needs an evidence-based gate. Canary Cage produces the contract, the proof by replay and the bundle a reviewer can file.

Expansion path. Per-tool contracts in MCP registries, a CI gate that re-runs the locked probe on every server version, policy export to the runtime that will host the tool.

LIMITS, STATED

# We say observed. We never say safe.

- Results hold for one recorded run. Baseline subtraction is useful, not proof, so an uncertain label exists.
- Executed processes are observed and compared with the contract, not prevented. Coverage is strace, gateway and DNS, with gaps listed.
- The fixture is synthetic and labelled so. Fixture answers and cached traces are labelled on screen.

VANTA POINT LABS

# Before an agent gets a tool, prove the tool can do its job with no more authority than it needs.

Timotej Cvikl, Bernard Liu, Jeremy Wong (advisor). MIT licence. Public repository, live Vultr URL and evidence bundles linked from the submission.